UAlg FCT
UNIVERSIDADE DO ALGARVE
FACULDADE DE CIÊNCIAS E TECNOLOGIA

Relatório Técnico: CVE-2026-28213

Mestrado em Cibersegurança

2 de março de 2026

1 Secção 1: Análise da Falha

A vulnerabilidade CVE-2026-28213 afeta versões do EverShop anteriores à 2.1.1, no fluxo de recuperação de palavra-passe. O problema acontece quando o endpoint de *reset password* devolve no corpo da resposta o *token* de reposição juntamente com o email. Na prática, este comportamento transforma um segredo temporário num dado público para qualquer cliente que consiga invocar o pedido. Isto é, qualquer pessoa com o webinspector de qualquer browser consegue capturar o token e depois usá-lo para construir um endereço onde toma controlo sobre a conta. A falha é crítica porque combina vetores remotos, baixa complexidade e ausência de interação do utilizador. O erro de desenho está na lógica de resposta da API, não no mecanismo criptográfico do token em si. Logo, mesmo que o token seja forte, ele foi exposto de forma indevida e os dados sensíveis ficam acessiveis.

2 Secção 2: Exploits e Violações de Código

O cenário de exploração é direto: o atacante submete um pedido de recuperação para um email alvo, recebe o *token* na resposta e usa esse mesmo token para definir uma nova palavra-passe. Como o processo depende da confidencialidade do token, a sua devolução quebra o modelo de segurança por completo. O trecho vulnerável observado devolvia explicitamente:

```
response.$body = {
        token,
        email
};
```

Por outro lado, o componente que actualiza a passoword precisa apenas do token e da nova palavra-passe, sem necessidade de o expor.

```
const { token, password } = body;
```

Isto constitui uma violação de princípios básicos de segurança aplicacional, nomeadamente minimização de dados e separação entre estado interno e resposta externa. Também há quebra de boas práticas de *password reset*, onde o token deve circular apenas por canal controlado (ex.: email legítimo do utilizador). Nesta falha, os controlos compensatórios são quase nulos, porque o próprio endpoint entrega o elemento de autenticação ao requisitante, o que permite um ataque quase imediata.

3 Secção 3: Remediação

A remediação principal é remover imediatamente o token da resposta HTTP, devolvendo apenas uma mensagem genérica de sucesso (por exemplo: *Se a conta existir, serão enviadas instruções*). Esta abordagem reduz enumeração de contas e impede fuga de segredos. Em paralelo, recomenda-se atualização para EverShop 2.1.1 ou superior, versão que corrige o comportamento vulnerável. Devem ainda ser aplicadas medidas complementares: limitação de taxa por IP e por conta, expiração curta de tokens, invalidação após uso único, registo/auditoria de pedidos de recuperação e alertas para padrões anómalos. A equipa deve executar revisão de código focada em endpoints sensíveis e adicionar testes automáticos para garantir que credenciais temporárias nunca aparecem em respostas. Por fim, é importante notificar utilizadores potencialmente afetados e forçar redefinição de palavra-passe quando existir evidência de abuso. Na pratica, os developers fizeram de imediato um hotfix para remover o token da resposta, e depois lançaram a versão 2.1.1 com a correção definitiva.

4 Secção 4: Vulnerabilidades Relacionadas

Esta CVE relaciona-se com classes conhecidas de fraquezas, incluindo CWE-200 (exposição de informação sensível) e CWE-640 (mecanismo fraco de recuperação de palavra-passe). Em sistemas web, falhas similares aparecem quando segredos de sessão, códigos OTP, links assinados ou *JWTs* são registados em *logs*, devolvidos em APIs ou refletidos no lado cliente. Outro padrão comum é a ausência de mensagens neutras no *forgot password*, permitindo enumeração de contas. Também se observa relação com falhas de desenho em autenticação multifator quando o segundo fator é tratado como dado meramente informativo. Embora a origem técnica varie, o efeito final costuma ser o mesmo: escalada para tomada de conta. Para reduzir risco sistémico, as organizações devem tratar tokens temporários como credenciais de alto valor e estabelecer controlos uniformes entre equipas, porque pequenos desvios de implementação podem causar impacto muito grande e os atacante exploram isso rapidamente.

5 Secção 5: Referências

- CVE Details – CVE-2026-28213: `https://www.cvedetails.com/cve/CVE-2026-28213/`
- GitHub Security Advisory (EverShop): `https://github.com/evershopcommerce/evershop/security/advisories/GHSA-cg73-g723-39jw`
- Release com correção (v2.1.1): `https://github.com/evershopcommerce/evershop/releases/tag/v2.1.1`
- Código afetado (commit de referência): `https://github.com/evershopcommerce/evershop/blob/70a786fadcbd55f1641f0088189da4cfe44aa79c/packages/evershop/src/modules/customer/api/resetPassword/%5BbodyParser%5DresetPassword.js#L35-L38`
- CWE-200: `https://cwe.mitre.org/data/definitions/200.html`
- CWE-640: `https://cwe.mitre.org/data/definitions/640.html`

- Codigo que actualiza a password (commit de referência): https://github.com/evershopcommerce/evershop/blob/70a786fadcbd55f1641f0088189da4cfe44aa79c/packages/evershop/src/modules/customer/api/updatePassword/%5BbodyParser%5DupdatePassword.js#L21